

Informe PILAR (ENS).

El marco PILAR-ENS ha cristalizado, desde 2025, en un sistema de indicadores que ya no se limita a “hacer un análisis de riesgos”, sino a **medir** de forma continua madurez, riesgo y cumplimiento frente al ENS como si fueran KPIs de negocio con traje criptográfico y corbata de auditoría.¹²³⁴⁵

De qué indicadores estamos hablando realmente

PILAR no inventa el riesgo, pero sí lo domestica en forma de números: niveles de 0 a 10 para requisitos de seguridad de los activos, niveles L0–L5 para madurez de salvaguardas y controles, probabilidades e impactos parametrizados, y un semáforo que traduce todo eso a un rojo/ámbar/verde muy comprensible para el comité de dirección.⁶⁷

Para los activos esenciales, la herramienta obliga a valorar la “demanda” de seguridad entre 0 (despreciable) y 10 (máxima) en cada dimensión: confidencialidad, integridad, disponibilidad, autenticidad, trazabilidad y, cuando corresponde, privacidad de datos personales. Esa cuadrícula de números por activo y por dominio de seguridad se ha convertido, en la práctica, en uno de los indicadores estructurales del ENS: expresa qué está realmente en juego antes de hablar de amenazas o controles.⁸⁹¹⁰

Sobre este lienzo, PILAR aplica perfiles estándar de amenazas y calcula riesgos potenciales y residuales, directos sobre activos de soporte e indirectos o repercutidos sobre activos de negocio; es decir, el mapa de “cuánto valor se nos puede evaporar” por cada combinación de activo, amenaza y dimensión de seguridad. El resultado son indicadores de riesgo que se pueden explotar tanto en clave técnica como de

1 <https://ens.ccn.cni.es/es/>

2 <https://administracionelectronica.gob.es/ctt/pilar>

3 <https://ens.ccn.cni.es/gl/soporte-ens/real-decreto-311-2022/capitulo/3/articulo/14>

4 https://portal.mineco.gob.es/es-es/ministerio/estrategias/Paginas/Esquema_Nacional_de_Seguridad.aspx

5 <https://ens.ccn.cni.es/es/>

6 <https://administracionelectronica.gob.es/ctt/pilar>

7 <https://ens.ccn.cni.es/es/>

8 https://portal.mineco.gob.es/es-es/ministerio/estrategias/Paginas/Esquema_Nacional_de_Seguridad.aspx

9 <https://ens.ccn.cni.es/es/>

10 <https://administracionelectronica.gob.es/ctt/pilar>

negocio, algo muy alineado con la filosofía del ENS actualizado y su énfasis en gestión de riesgos documentada y proporcional.¹¹¹²¹³¹⁴

Madurez como métrica troncal (L0-L5, CMM en versión ENS)

Desde 2025, los manuales de PILAR empujan claramente hacia una lectura basada en madurez de salvaguardas y controles, reutilizando un modelo tipo CMM (L0-L5) que ya no es sólo narrativa de auditor, sino fuente de indicadores cuantitativos.¹⁵¹⁶

Los niveles son:

- L0 inexistente: ni rastro de la medida.
- L1 ad hoc: hay algo, pero depende de buena suerte y héroes puntuales.
- L2 reproducible intuitivo: la organización repite éxitos, pero sin proceso robusto.
- L3 proceso definido: políticas, procedimientos y mantenimiento sistemático.
- L4 gestionado y medible: la dirección controla empíricamente eficacia y efectividad.
- L5 optimizado: mejora continua con objetivos cuantitativos y ajustes periódicos.²¹

La gracia moderna está en cómo se explotan estos niveles:

- Se miden por fase de proyecto (situación actual, objetivo, recomendación de PILAR), permitiendo ver la evolución temporal de la seguridad.¹²
- Se pueden reinterpretar como porcentaje de efectividad o comparar “madurez real” frente a la recomendación de la herramienta, lo que convierte el nivel en un KPI directamente consumible por dirección.²¹
- Se mantiene la distinción entre madurez técnica de salvaguardas y madurez formal de controles, lo que deja espacio para que la vida real (controles parcialmente implantados, normas algo anacrónicas) se exprese en forma de dos números, no en discusiones metafísicas.²

En el contexto ENS, donde el real decreto exige gestión periódica del riesgo con medidas justificadas y proporcionales, esta madurez numérica funciona como indicador de “cuán sólidamente” están implantadas las medidas del anexo II más allá de la mera existencia documental.¹⁷¹⁸

¹¹ <https://ens.ccn.cni.es/es/>

¹² https://www.pilar-tools.com/doc/manual_basic_es_2025.pdf

¹³ <https://administracionelectronica.gob.es/ctt/pilar>

¹⁴ https://portal.mineco.gob.es/es-es/ministerio/estrategias/Paginas/Esquema_Nacional_de_Seguridad.aspx

¹⁵ <https://ens.ccn.cni.es/es/>

¹⁶ <https://administracionelectronica.gob.es/ctt/pilar>

¹⁷ https://portal.mineco.gob.es/es-es/ministerio/estrategias/Paginas/Esquema_Nacional_de_Seguridad.aspx

Semáforos, recomendaciones y el arte de priorizar

PILAR sabe que la alta dirección no va a leer cien páginas de detalles técnicos, de modo que introduce una batería de indicadores pensados para priorizar sin necesidad de lupa:

- Recomendación (0–10): la herramienta estima la importancia relativa de cada medida de seguridad, teniendo en cuenta activos, niveles de seguridad requeridos y riesgos que trata. Una celda gris indica que la medida no tiene, para ese sistema, ningún riesgo evidente al que agarrarse; es un “esto aquí no pinta nada” cuantificado.¹²
- Overkill (o) y underkill (u): etiquetas que señalan cuando una medida parece desproporcionada (más allá de lo necesario) o claramente insuficiente frente a los riesgos identificados. Como indicadores, convierten discusiones bizantinas sobre controles “excesivos” o “muy caros” en cuestiones relativamente objetivables.¹²
- Aplicabilidad: la columna en la que se indica si cada control o salvaguarda es aplicable o no, con la particularidad de que PILAR conserva un color distintivo cuando se marca “no aplicable” un control que la norma considera obligatorio, exponiendo la excepcionalidad para futuras auditorías.²¹

El semáforo combina estos elementos con las fases de madurez:

- Se designa una fase objetivo (cabecera verde) y una fase evaluada (cabecera roja).
- Para cada medida, el color azul indica que la madurez actual está por encima del objetivo, verde que está a la altura, amarillo que va por debajo y rojo que está sensiblemente por debajo; gris, de nuevo, es no aplicable.¹²

Lo relevante en clave ENS es que este semáforo ya no es un mero adorno gráfico: se ha convertido en indicador sintético de cumplimiento y de riesgo residual, porque refleja en una sola vista cuántas medidas críticas (por peso) están en rojo o amarillo en los dominios donde la exposición de activos es mayor.¹⁹²⁰²¹²²

¹⁸ <https://ens.ccn.cni.es/es/>

¹⁹ <https://ens.ccn.cni.es/gl/soporte-ens/real-decreto-311-2022/capitulo/3/articulo/14>

²⁰ https://portal.mineco.gob.es/es-es/ministerio/estrategias/Paginas/Esquema_Nacional_de_Seguridad.aspx

²¹ <https://administracionelectronica.gob.es/ctt/pilar>

²² <https://ens.ccn.cni.es/es/>

Dominios, dependencias y riesgos repercutidos: indicadores de arquitectura y exposición

Una de las tendencias técnicas más notables, que casa muy bien con Zero Trust sin necesidad de nombrarlo, es el uso intensivo de dominios de seguridad, zonas y dependencias como base de indicadores sobre arquitectura y superficie de ataque.²³²⁴²⁵

Los dominios de seguridad agrupan activos con un perfil de ataque y de protección homogéneo, y permiten heredar niveles de madurez de salvaguardas entre dominios padre e hijo. Esto no sólo reduce trabajo operativo: crea indicadores de cobertura “por dominio” que se parecen sospechosamente a las métricas de segmentación de redes en arquitecturas modernas, donde no basta con tener un firewall, sino con demostrar que los niveles de protección están alineados con los requisitos de los activos anidados.²⁶²⁷

Las dependencias entre activos permiten refinar la transferencia de valor y de requisitos de seguridad, evitando el supuesto ingenuo de que todos los servidores son igual de críticos para todas las informaciones. Esto da lugar a indicadores más finos:²⁸

- Riesgo acumulado sobre activos de soporte concretos: qué suma de valor “pasa” por cada hardware, software, red, instalación, usuario.
- Riesgo repercutido hacia activos esenciales: cuánta repercusión hacia negocio tiene cada amenaza que impacta un activo aparentemente “de infraestructura”.²

Con la introducción de nodos OR, PILAR puede diferenciar caminos alternativos de provisión de servicio, evitando trasladar mecánicamente requisitos de disponibilidad a todos los elementos cuando existe redundancia. Esto se traduce en indicadores más inteligentes sobre puntos únicos de fallo, que son oro puro para la resiliencia digital y la continuidad de negocio.²⁹

La noción de zonas (lógicas, físicas, TEMPEST) permite además un análisis de defensa en profundidad que desemboca en indicadores sobre:

²³ <https://ens.ccn.cni.es/gl/soporte-ens/real-decreto-311-2022/capitulo/3/articulo/14>

²⁴ <https://administracionelectronica.gob.es/ctt/pilar>

²⁵ <https://ens.ccn.cni.es/es/>

²⁶ <https://administracionelectronica.gob.es/ctt/pilar>

²⁷ <https://ens.ccn.cni.es/es/>

²⁸ <https://administracionelectronica.gob.es/ctt/pilar>

²⁹ <https://administracionelectronica.gob.es/ctt/pilar>

- Cantidad y criticidad de activos en cada zona.
- Robustez de las fronteras, modeladas como activos que concentran perfiles de ataque y salvaguardas específicas.¹²

En un ENS donde la protección perimetral clásica convive con entornos híbridos, estas métricas de zonas y fronteras se integran de facto como indicadores de “arquitectura segura”, incluso cuando el texto legal no entra tan fino.³⁰³¹

Perfiles de seguridad, ENS y cumplimiento medible

PILAR incorpora perfiles de seguridad alineados con normas internacionales (ISO 27002, NIST SP 800-53) y con perfiles específicos (EVL, CCN-STIC) que permiten medir simultáneamente tratamiento del riesgo y cumplimiento normativo.³²³³³⁴³⁵

En el ámbito ENS, el fichero de configuración STIC y los perfiles asociados son el puente explícito: permiten cargar conjuntos de controles equivalentes a las medidas del anexo II y valorar su madurez, aplicabilidad y recomendación con la misma semántica de L0–L5 y semáforos. El resultado es un conjunto de indicadores de cumplimiento tales como:³⁶³⁷³⁸

- Porcentaje de medidas ENS marcadas como aplicables que se encuentran en nivel de madurez igual o superior al recomendado.
- Número de controles obligatorios marcados como no aplicables, con sus correspondientes comentarios, algo extremadamente visible para inspecciones y procesos de certificación.²

La separación entre madurez formal de los controles y madurez real de las salvaguardas asociadas es otra tendencia significativa: permite que los indicadores distingan entre el “expediente” (lo que se declara en documentos de cumplimiento) y la efectividad práctica (lo que realmente reduce el riesgo en el sistema). Poder mostrar, por ejemplo, un control valorado formalmente en L3 mientras las

³⁰ <https://ens.ccn.cni.es/es/>

³¹ <https://ens.ccn.cni.es/es/>

³² https://www.pilar-tools.com/doc/manual_basic_es_2025.pdf

³³ <https://ens.ccn.cni.es/gl/soporte-ens/real-decreto-311-2022/capitulo/3/articulo/14>

³⁴ <https://ens.ccn.cni.es/es/>

³⁵ <https://administracionelectronica.gob.es/ctt/pilar>

³⁶ <https://ens.ccn.cni.es/gl/soporte-ens/real-decreto-311-2022/capitulo/3/articulo/14>

³⁷ https://portal.mineco.gob.es/es-es/ministerio/estrategias/Paginas/Esquema_Nacional_de_Seguridad.aspx

³⁸ <https://administracionelectronica.gob.es/ctt/pilar>

salvaguadas asociadas están en un rango L1–L5 introduce un saludable grado de honestidad cuantitativa que los comités de riesgo valoran cada vez más.³⁹

Finalmente, el tratamiento del riesgo en PILAR admite usar distintos catálogos de salvaguadas (propias, NIST, perfiles EVL) como base de las decisiones de mitigación; el hecho de poder decidir cuáles se usan para tratar el riesgo y cuáles se limitan a cumplimiento añade capas de indicadores diferenciando lo que se hace “para bajar el riesgo” de lo que se hace “para pasar la auditoría”.⁴⁰

Tendencias desde 2025: más cuantificación, más automatización, más alineamiento ENS

Si uno mira el manual 2025 de PILAR y las actualizaciones recientes del soporte ENS, se perciben varias tendencias convergentes.⁴¹⁴²⁴³⁴⁴⁴⁵⁴⁶

Primero, la consolidación de indicadores cuantitativos: no sólo riesgo como producto de probabilidad e impacto, sino madurez, recomendación, pesos de salvaguadas (crítica, muy importante, importante, interesante) y métricas derivadas como porcentaje de efectividad. Esta proliferación no es caprichosa: responde a la necesidad de métricas e indicadores de ciberseguridad para la toma de decisiones estratégicas, que el propio portal ENS subraya como requisito para conocer el estado de seguridad de los sistemas que soportan la Administración digital.⁴⁷⁴⁸⁴⁹⁵⁰

Segundo, una automatización más agresiva: la transferencia de valor de activos esenciales a activos de soporte, la aplicación de perfiles estándar de amenaza (TSV o similares), la sugerencia de salvaguadas en función de clase de activo, niveles de seguridad y capacidades de protección, e incluso el cálculo de

³⁹ <https://administracionelectronica.gob.es/ctt/pilar>

⁴⁰ <https://administracionelectronica.gob.es/ctt/pilar>

⁴¹ <https://ens.ccn.cni.es/gl/soporte-ens/real-decreto-311-2022/capitulo/3/articulo/14>

⁴² https://portal.mineco.gob.es/es-es/ministerio/estrategias/Paginas/Esquema_Nacional_de_Seguridad.aspx

⁴³ <https://ens.ccn.cni.es/es/>

⁴⁴ <https://ens.ccn.cni.es/gl/soporte-ens/real-decreto-311-2022/capitulo/3/articulo/14>

⁴⁵ <https://ens.ccn.cni.es/es/>

⁴⁶ <https://administracionelectronica.gob.es/ctt/pilar>

⁴⁷ <https://ens.ccn.cni.es/gl/soporte-ens/real-decreto-311-2022/capitulo/3/articulo/14>

⁴⁸ <https://ens.ccn.cni.es/es/>

⁴⁹ <https://ens.ccn.cni.es/gl/soporte-ens/real-decreto-311-2022/capitulo/3/articulo/14>

⁵⁰ <https://administracionelectronica.gob.es/ctt/pilar>

recomendaciones y colores de semáforo se realizan de forma automática, dejando al analista en el rol de corrector, no de “calculadora humana”. Esta tendencia encaja con el enfoque ENS de gestionar riesgos con metodologías reconocidas y herramientas que permitan repetir análisis y auditar decisiones sin depender de la memoria del consultor.⁵¹⁵²⁵³⁵⁴⁵⁵

Tercero, una integración más clara con el ciclo de vida: las fases de proyecto conectadas, en las que cada fase refina la anterior y la madurez se hereda hasta que se reevalúa, convierten el análisis de riesgos en un proceso continuo. El ENS, que exige revisión periódica del análisis y de las medidas adoptadas, encuentra aquí una forma natural de expresar ese ciclo en indicadores: cuánto hemos avanzado de la fase “actual” a la fase “objetivo”, qué medidas siguen en rojo tras dos iteraciones, qué dominios han mejorado o empeorado su madurez media.⁵⁶⁵⁷⁵⁸

Por último, la apertura a catálogos externos (NIST, EVL, CVE) y el uso de bases de datos SQL para almacenar proyectos y resultados amplían el rango posible de indicadores: se pueden construir cuadros de mando agregados, identificar tendencias de vulnerabilidades explotadas, correlacionar riesgos con activos compartidos entre organizaciones y, en resumen, elevar el juego desde el caso individual al análisis sectorial, algo muy del gusto de organismos reguladores y centros de respuesta nacionales.⁵⁹⁶⁰⁶¹⁶²

1011121314159

51 https://portal.mineco.gob.es/es-es/ministerio/estrategias/Paginas/Esquema_Nacional_de_Seguridad.aspx

52 <https://ens.ccn.cni.es/es/>

53 <https://ens.ccn.cni.es/gl/soporte-ens/real-decreto-311-2022/capitulo/3/articulo/14>

54 <https://ens.ccn.cni.es/es/>

55 <https://administracionelectronica.gob.es/ctt/pilar>

56 <https://ens.ccn.cni.es/es/>

57 https://portal.mineco.gob.es/es-es/ministerio/estrategias/Paginas/Esquema_Nacional_de_Seguridad.aspx

58 <https://administracionelectronica.gob.es/ctt/pilar>

59 <https://angeles.ccn-cert.cni.es/es/cursos-stic/xviii-curso-analisis-y-gestion-de-riesgos-de-los-sistemas-de-informacion-pilar>

60 https://www.pilar-tools.com/doc/manual_basic_es_2025.pdf

61 <https://ens.ccn.cni.es/gl/inicio>

62 <https://www.gtt.es/boletinjuridico/publicadas-las-guias-ccn-stic-sobre-el-analisis-de-riesgos-para-eell-y-sobre-la-declaracion-y-certificacion-de-conformidad-con-el-ens/>